SecureCorp Security Assessment

Final Assessment Report

1. Executive Summary

This project documents a cybersecurity assessment conducted in an isolated VirtualBox lab using Kali Linux and Metasploitable2.

The assessment focused on network reconnaissance, service identification, HTTP security observations, WebDAV configuration review, and basic authentication-log monitoring.

The assessment identified legacy software versions, server-version disclosure, WebDAV-related exposure requiring further validation, and a potentially serious service exposed on TCP port 1524.

Basic UDP packet delivery was demonstrated on port 5514. However, standard remote syslog forwarding and centralized Wazuh log ingestion have not been verified.

This report documents the observations, supporting evidence, limitations, and recommended remediation steps.

2. Scope and Environment

Lab Environment

- Assessment system: Kali Linux
- Target system: Metasploitable2
- Kali lab IP: `10.10.10.5`
- Target lab IP: `10.10.10.10`
- Network: Isolated VirtualBox Internal Network

Scope

The assessment included:

- Lab network and connectivity checks

- Nmap service discovery
- Service identification
- FTP anonymous-access verification
- HTTP response-header inspection
- WebDAV configuration review
- DVWA login-page review
- TCP port 1524 observation
- Authentication-log review
- Remote UDP/syslog investigation

All testing was limited to the designated educational lab environment.

3. Assessment Methodology

The assessment followed these stages:

1. Lab setup and network configuration
2. Network reconnaissance and service discovery
3. Review of HTTP headers and WebDAV responses
4. Limited application-page inspection
5. Authentication-log analysis
6. UDP connectivity testing
7. Evidence documentation
8. Findings and remediation recommendations

4. Findings

Finding 1: Legacy Service and Software Versions

Observation: The target's HTTP response identified Apache 2.2.8 and PHP 5.2.4.

Potential Risk: Unsupported or unpatched software may contain known vulnerabilities. The observed version information alone does not confirm exploitability.

Severity: Medium — preliminary assessment; further validation required.

Evidence: `Week-2-Red-Team/evidence/http-headers.txt`

Recommendations:

- Upgrade unsupported software to maintained versions.
- Apply security patches.
- Disable unnecessary services.
- Restrict network access to required services.

Finding 2: HTTP Server Information Disclosure

Observation: HTTP response headers disclosed server and PHP version information.

Potential Risk: Version disclosure can help an attacker identify software for further investigation. Disclosure alone does not establish that the target is exploitable.

Severity: Low — preliminary assessment.

Evidence: `Week-2-Red-Team/evidence/http-headers.txt`

Recommendations:

- Minimize unnecessary server-version disclosure.
- Keep server software updated.
- Review HTTP response headers and server configuration.

Finding 3: WebDAV Service Exposure

Observation: WebDAV-related HTTP capabilities were investigated. The OPTIONS response advertised several WebDAV-related methods, and a PROPFIND request returned a multistatus response.

Potential Risk: Inappropriate WebDAV permissions or unnecessary write access may allow unauthorized file operations. The observed responses do not independently establish that unauthorized modification was possible.

Severity: Requires further verification.

Evidence:

- `Week-2-Red-Team/evidence/webdav-options.txt`
- `Week-2-Red-Team/evidence/webdav-propfind.txt`
- `Week-2-Red-Team/evidence/webdav-directory.html`
- `Week-2-Red-Team/evidence/webdav-get-headers.txt`
- `Week-2-Red-Team/evidence/E06-webdav-options.png`

Recommendations:

- Disable WebDAV if it is not required.
- Restrict access to authorized users.
- Disable unnecessary write methods.
- Review permissions and access logs.

Finding 4: Centralized Syslog Forwarding Not Verified

Observation: Authentication logs were reviewed on Kali Linux. A separate UDP connectivity test captured one packet from Metasploitable2 (`10.10.10.10`) to Kali (`10.10.10.5`) on UDP port 5514.

The UDP packet capture confirms connectivity for that test. It does not confirm successful standard syslog forwarding on UDP port 514 or centralized log ingestion by Wazuh.

Potential Risk: Without verified centralized logging, security events may be harder to correlate and investigate across systems.

Status: Partially tested; centralized logging remains unverified.

Evidence:

- `Week-3-Blue-Team/evidence/kali-auth-monitoring.txt`
- `Week-3-Blue-Team/evidence/syslog-udp-test.txt`

Recommendations:

- Troubleshoot and verify remote syslog configuration.
- Confirm that test messages arrive at the intended receiver.
- Verify log storage and ingestion.
- Protect logs against unauthorized modification.
- Establish log-retention and review procedures.

Finding 5: Root-Shell Prompt Observed on TCP Port 1524

Observation: A connection to the Metasploitable2 target (`10.10.10.10`) on TCP port 1524 displayed the prompt `root@metasploitable:/#`.

No additional commands were executed within the observed shell, and command execution was not independently verified.

Potential Impact: If the service provides unauthorized root-level access, it could expose the target to severe compromise.

Severity: Critical potential impact — service configuration and access must be validated.

Evidence: `Week-2-Red-Team/evidence/E07-port-1524-root-shell.txt`

Recommendations:

- Disable the service if it is not required.
- Restrict access to necessary lab systems.

- Investigate unexpected connections to TCP port 1524.
- Monitor relevant network and system logs.

5. Blue Team Monitoring

Kali Linux authentication logs in `/var/log/auth.log` were reviewed for administrative commands and session activity.

The collected evidence contains sudo command records and session-open/session-close events.

No failed-login event was confirmed in the reviewed output. This does not establish that failed logins never occurred elsewhere or at other times.

A UDP packet was captured on port 5514 during a separate connectivity test. Standard syslog forwarding and centralized Wazuh ingestion remain unverified.

6. Limitations

- Testing was performed in an isolated educational lab.
- The assessment was not a complete penetration test.
- Findings require additional validation before being treated as confirmed exploitable vulnerabilities.
- No commands were executed after the root-shell prompt on TCP port 1524 was observed.
- WebDAV unauthorized write access was not confirmed.
- UDP connectivity on port 5514 does not establish successful syslog forwarding on port 514.
- Wazuh installation, service status, and centralized log ingestion have not been verified.
- The assessment does not claim that every vulnerability or security weakness on the target was identified.

7. Remediation Priorities

1. Upgrade unsupported software and apply security updates.
2. Review exposed services and disable unnecessary services.
3. Validate WebDAV permissions and restrict access.
4. Investigate and secure the service observed on TCP port 1524.
5. Complete and validate centralized logging.
6. Establish regular log review and evidence-retention procedures.

8. Conclusion

The SecureCorp Security Assessment provided practical experience with network reconnaissance, service identification, HTTP and WebDAV review, evidence collection, and authentication-log analysis.

The assessment documented several security concerns requiring remediation or further validation. Basic UDP packet delivery was demonstrated, but centralized security monitoring remains incomplete.

Recommended next steps are to validate the findings, remediate confirmed weaknesses, and verify that logging and monitoring controls operate as intended.

9. Evidence Index

- Nmap service scan: `Week-2-Red-Team/metasploitable-scan.txt`
- HTTP headers and server version: `Week-2-Red-Team/evidence/http-headers.txt`
- WebDAV OPTIONS review: `Week-2-Red-Team/evidence/webdav-options.txt`
- WebDAV PROPFIND response: `Week-2-Red-Team/evidence/webdav-propfind.txt`
- WebDAV directory response: `Week-2-Red-Team/evidence/webdav-directory.html`
- WebDAV GET headers: `Week-2-Red-Team/evidence/webdav-get-headers.txt`
- WebDAV screenshot: `Week-2-Red-Team/evidence/E06-webdav-options.png`
- DVWA login-page review: `Week-2-Red-Team/evidence/dvwa-login-review.txt`
- TCP port 1524 observation: `Week-2-Red-Team/evidence/E07-port-1524-root-shell.txt`
- Authentication-log review: `Week-3-Blue-Team/evidence/kali-auth-monitoring.txt`
- UDP connectivity test: `Week-3-Blue-Team/evidence/syslog-udp-test.txt`

10. Assessment Status

Project: SecureCorp Security Assessment **Environment:** Isolated VirtualBox lab **Status:** Assessment observations and evidence documented; centralized logging and further validation remain pending.